

Podstawy Ochrony Danych

► Wykład

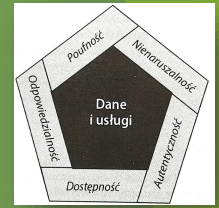
Na tej lekcji omówimy:

- ▶ Jakie aktywa (dobra powinniśmy chronić)?
- ▶ Na co są one narażone?
- ▶ Co możemy zrobić, aby przeciwstawić się tym zagrożeniom?

Bezpieczeństwo komputerowe

Środki i regulacje zapewniające poufność, nienaruszalność i dostępność aktywów systemu informacyjnego , w tym sprzętu, oprogramowania, programów fabrycznie wbudowanych (firmware) oraz przetwarzanych, przechowywanych i komunikowanych informacji

Cele bezpieczeństwa komputerowego



Poufność

Zachowanie autoryzowanych ograniczeń dostępu do informacji i ich ujawniania, w tym środków ochrony prywatności i informacji zastrzeżonych.

Utrata poufności to nieuprawnione ujawnienie informacji.



Integralność

Ochrona przed niewłaściwą modyfikacją lub zniszczeniem informacji, w tym zapewnienie niezaprzeczalności i autentyczności informacji.

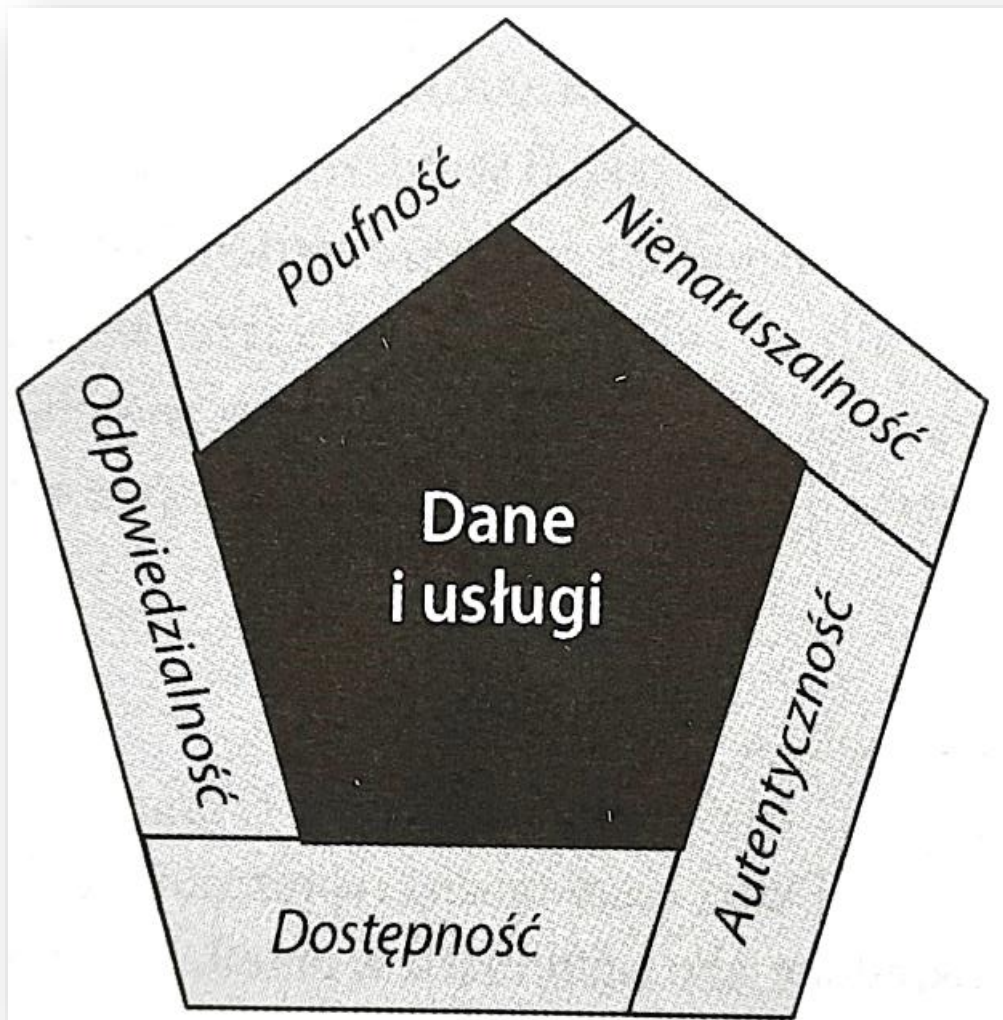
Utrata integralności to nieautoryzowana modyfikacja lub zniszczenie informacji.



Dostępność

Zapewnienie terminowego i niezawodnego dostępu do informacji i ich wykorzystani.

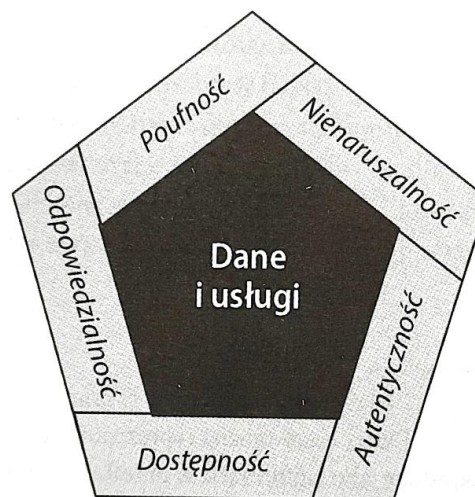
Utrata dostępności to zakłócenie dostępu do informacji lub korzystania z nich.



Istotne wymagania nakładane na bezpieczeństwo sieci i komputerów

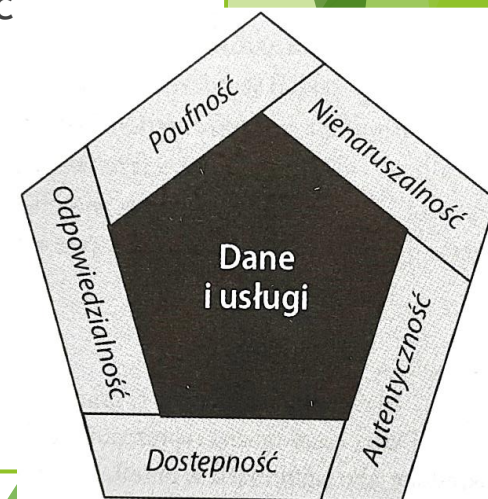
Istotne wymagania nakładane na bezpieczeństwo sieci i komputerów

► **Autentyczność:** właściwość bycia autentycznym i bycia w stanie być zweryfikowanym i zaufanym; pewność co do ważności transmisji, wiadomości. Oznacza to sprawdzenie, czy użytkownicy są tym, za kogo się podają, i że każde dane wejściowe przychodzące do systemu, pochodzą z zaufanego źródła.



Istotne wymagania nakładane na bezpieczeństwo sieci i komputerów

- ▶ Odpowiedzialność [accountability]: Cel bezpieczeństwa generujący wymagania aby **działania jednostki były jednoznacznie przypisane** danej jednostce.
- ▶ Jest to pomocne w osiągnięciu **niezaprzeczalności**, powstrzymywaniu, izolowaniu usterek, wykrywaniu naruszeń i zapobieganiu im oraz w działaniach naprawczych i postępowaniu prawnym po fakcie.
- ▶ Ponieważ prawdziwie bezpieczne systemy nie są jeszcze osiągalne musimy być w stanie **prześledzić** naruszenie bezpieczeństwa
- ▶ Systemy muszą prowadzić **rejstry** swoich **działań**, aby umożliwić późniejszą analizę kryminalistyczną, w celu śledzenia naruszeń bezpieczeństwa lub pomocy w sporach dotyczących transakcji.



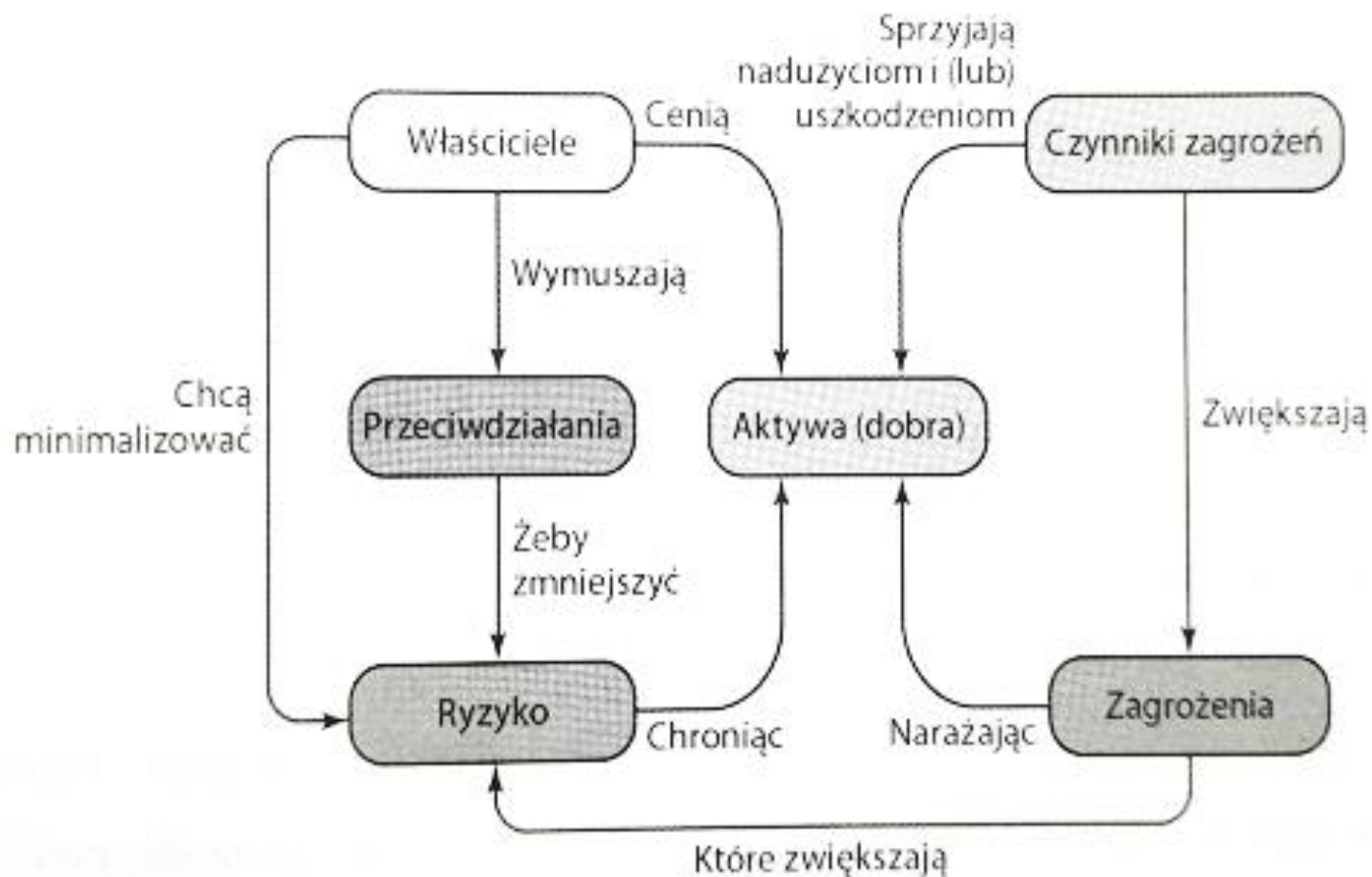
Terminologia bezpieczeństwa komputerowego

- ▶ **Przeciwnik** - czynnik zagrożenia - osoba, grupa, organizacja lub rząd, prowadzące lub zamierzające prowadzić szkodliwe działania
- ▶ **Atak** - wszelkiego rodzaju złośliwe działanie, mające na celu gromadzenie, uszkodzenie, unieruchomienie, pogorszenie lub zniszczenie zasobów systemu informacyjnego lub samych informacji
- ▶ **Przeciwdziałanie**- środki zaradcze- urządzenia lub techniki, których celem jest uniemożliwienie skuteczności niepożądanych, nieprzyjacielskich działań, albo zapobieżenie szpiegostwu, sabotażowi, nieupoważnionemu dostępowi do/lub wykorzystania wrażliwych informacji lub systemów informacyjnych
- ▶ **Ryzyko** - miara narażenia danej jednostki na potencjalne okoliczności lub zdarzenie i :
 - ▶ szkodliwego wpływu przez jaki wystąpienie takich okoliczności lub zdarzeń może wywołać
 - ▶ prawdopodobieństwo ich wystąpienia

Terminologia bezpieczeństwa komputerowego

- ▶ **Polityka bezpieczeństwa** - zasady bezpieczeństwa- zbiór kryteriów zapewnienia usług bezpieczeństwa ; Definiuje i ogranicza działania w zakresie przetwarzania danych w celu utrzymania stanu bezpieczeństwa systemów i danych
- ▶ **Zasób systemu - aktywa - dobro** - główna aplikacja , ogólny system wspomagania, program o dużym znaczeniu, instalacja fizyczna , system o krytycznym znaczeniu dla działania , personel, wyposażenie lub grupa logicznie powiązanych systemów
- ▶ **Zagrożenie** - dowolna okoliczność lub zdarzenie o potencjalnie wrogim wpływie na działania organizacji (funkcje, wizerunek, reputację), aktywa organizacyjne, osoby, naród. Te działania odbywają się za pośrednictwem systemu informacyjnego w drodze nieupoważnionego dostępu, uszkodzenia, przez ujawnienie/modyfikację informacji i/lub odmowę świadczenia usług
- ▶ **Słabość - czuły punkt**- niedomaganie w systemie informacyjnym, słabość procedur bezpieczeństwa systemu, kontroli wewnętrznej lub implementacji, która może być wykorzystana lub uruchomiona przez źródło zagrożenia

Zależności między niektórymi z podstawowych terminów bezpieczeństwa komputerowego



Zasoby systemu komputerowego



Słabości, zagrożenia i ataki

Kategorie podatności

- ▶ **Uszkodzony** (utrata integralności)
- ▶ **Nieszczelny** (utrata poufności)
- ▶ **Niedostępny** lub bardzo powolny (utrata dostępności)

Ataki

- ▶ **Pasywny** - próba uczenia się lub wykorzystywania informacji z systemu ; atak nie ma wpływu na zasoby systemowe
- ▶ **Aktywny** - próba zmiany zasobów systemowych lub wpłynięcia na ich działanie
- ▶ **Wewnętrzny** - inicjowany przez jednostkę wewnątrz parametru bezpieczeństwa
- ▶ **Zewnętrzny** - inicjowany spoza obwodu

Środki zaradcze/ przeciwstawienie się atakowi

- ▶ Idealnie gdyby środki zaradcze zapobiegły atakowi
- ▶ Jednak gdy doszło do ataku to ważne jest jego wykrycie
- ▶ Usunięcie skutków i przywrócenie zdolności do działania
- ▶ Przeciwśrodki mogą same wykazywać nowe słabości

Zagrożenia i ataki - Nieupoważnione ujawnienie

Nieupoważnione ujawnienie jest zagrożeniem poufności, i może spowodować następujące skutki :

- ▶ **Wystawienie na widok**- celowe jeżeli ktoś z wewnątrz celowo udostępnia poufne informacje komuś z zewnątrz. Albo niecelowe jeżeli na skutek błędu człowieka, sprzętu lub oprogramowania jednostka uzyskuje w sposób nieupoważniony wiedzę o wrażliwych danych
- ▶ **Przechwycenie** do którego dochodzi podczas komunikacji. Na przykład jeżeli pracujemy w sieci zryło zgłaszaniem typu broadcast czyli pakiety wysyłane są do wszystkich urządzeń nieupoważniony komputer może odebrać kopię pakietów nieprzeznaczonych dla niego

Zagrożenia i ataki - Nieupoważnione ujawnienie

- ▶ **Wnioskowanie** to działanie podczas którego przeciwnikowi udaje się zebrać informacje na podstawie obserwowania pewnych regularności ruchów sieci takich jak natężenie ruchu między poszczególnymi parami węzłów sieci. Inny przykład to wnioskowanie szczegółowych informacji z bazy danych Kiedy to Użytkownik przez powtarzanie zapytań docieka wyników danych
- ▶ **Włamanie** czyli przejęcie nieupoważnionego dostępu do wrażliwych danych przez obejście ochrony [na przykład w postaci systemowej kontroli dostępu]

Zagrożenia i ataki

Oszustwo zagraża integralności systemu lub nienaruszalności danych. A oto przykłady :

- ▶ **Maskarada** to usiłowanie przez nieupoważnionego użytkownika zdobycia dostępu do systemu poprzez **udawanie** użytkownika upoważnionego. Może do tego dojść, jeśli nieupoważniony użytkownik poznał login i hasło upoważnionego użytkownika. Inny przykład to **koń trojański** który służy do zdobycia nielegalnego dostępu do zasobów lub do skłonienia użytkownika do wykonania innego niebezpiecznego programu
- ▶ **Podrobienie/fałszerstwo** to zmiana poprawnych danych ich wprowadzenie fałszywych do pliku lub bazy danych.

Zagrożenia i ataki

Oszustwo zagraża integralności systemu lub nienaruszalności danych. A oto przykłady :

- ▶ **Zaprzeczenie / odmowa** ma miejsce wtedy kiedy użytkownik albo odmawia wysłania danych , albo odmawia ich przyjęcia

Zagrożenia i ataki

Zakłócenie jest zagrożeniem związanym z dostępnością lub nienaruszalnością system. Typy ataków :

- ▶ **Unieruchomienie** następuje wskutek fizycznego **uszkodzenia** sprzętu system, lub złośliwe oprogramowanie w postaci konia trojańskiego, wirusów, robaków może **wyłączyć** część usług lub całkowicie **unieruchomić** system
- ▶ **Uszkodzenie/zepsucie** to atak na integralność system. złośliwe oprogramowanie może spowodować że zasoby systemu lub jego usługi zaczną **zachowywać się w niepożądany** sposób. Nieupoważniony użytkownik może umieścić w systemie **logikę tylnych drzwi (backdoor)** aby zapewnić sobie dostęp do systemu i jego zasobów innym sposobem niż za pośrednictwem rutynowej procedury.

Zagrożenia i ataki

Zakłócenie jest zagrożeniem związanym z dostępnością lub nienaruszalnością system. Typy ataków :

- ▶ **Obstrukcja/zablokowanie** polega na **odcięciu** systemu od łączy komunikacyjnych lub zmianie informacji sterujących komunikacją . Inna metoda polega na **przeładowaniu** systemu przez nadmierne obarczenie go ruchem lub przetwarzaniem danych

Zagrożenia i ataki

Uzurpacja jest zagrożeniem integralności systemu i może skutkować atakami :

- ▶ **Sprzeniewierzenie** może obejmować kradzież usług a przykładem jest rozproszony atak typu **odmowa usług (denial of service)** , kiedy złośliwe oprogramowanie zainstalowane na wielu komputerach w sieci, zostaje wykorzystane jako odskocznia, do powodowania nasilenia ruchu w docelowym hoście. W wyniku ataku procesor i zasoby systemu operacyjnego zostają zajęte i host nie jest w stanie i świadczyć swoich usług.

Zagrożenia i ataki

Uzurpacja jest zagrożeniem integralności systemu i może skutkować atakami :

- ▶ **Nadużycie** może wystąpić w postaci złośliwej logiki lub jako efekt działania osoby nielegalnie przenikającej do system. W obu przypadkach funkcje bezpieczeństwa mogą zostać wyłączone lub udaremnione.

Aktywa komputerowe i sieciowe z przykładami zagrożeń

	Dostępność	Poufność	Nienaruszalność
Sprzęt	Wypożyczenie zostało skradzione lub unieruchomione, uniemożliwiając świadczenie usług	Zdeszyfrowany napęd usb	
Oprogramowanie	Usunięto programy, co uniemożliwia dostęp do nich użytkownikom	Wykonano kopię bezpieczeństwa oprogramowania bez upoważnienia	Działający program jest modyfikowany, aby spowodować awarię podczas wykonywania lub wykonać niepożądane zadanie
Dane	Następuje usunięcie plików, co uniemożliwia dostęp do nich użytkownikom	Wykonano nielegalne czytanie danych	Istniejące pliki zostały zmodyfikowane lub sfabrykowane nowe pliki
Sieci i linie komunikacyjne	Komunikaty zostają zniszczone lub usunięte. Linie Komunikacyjne lub sieci stają się niedostępne	Następuje czytanie komunikatów. Obserwowana jest charakterystyka ruchu komunikatów	Komunikaty są modyfikowane, usuwane , zmieniona zostaje ich kolejność lub ulegają podwojeniu . Dochodzi do fabrykowania fałszywych komunikatów

Atak pasywny

- ▶ Próba uczenia się lub wykorzystania informacji z systemu; ale nie wpływa na zasoby systemowe
- ▶ Podstuchiwanie lub monitorowanie transmisji
- ▶ Celem atakującego jest uzyskanie informacji, które są przesyłane
- ▶ Dwa typy:
 - ▶ pozyskanie treści wiadomości
 - ▶ analiza ruchu

Atak aktywny

- ▶ Próby zmiany zasobów systemowych lub wpływania na ich działanie
- ▶ Obejmują pewną modyfikację strumienia danych lub utworzenie fałszywego strumienia
- ▶ Cztery kategorie:
 - ▶ Powtarzanie
 - ▶ Maskarada
 - ▶ Modyfikacja wiadomości
 - ▶ Odmowa usługi

Podsumowanie:

- ▶ Jakie aktywa (dobra powinniśmy chronić)?
- ▶ Na co są one narażone?
- ▶ Co możemy zrobić, aby przeciwstawić się tym zagrożeniom?